

NIP first ARB — 35-minute walk

Talk ~35 minutes. Leave ~25 for the board. Do not fill the hour.

Opening (45 seconds)

Good morning. This is the first architecture review of the Insurance Distribution Platform.

Today we walk the intended design: the problem, one sale as it will actually run, the runtime, and the stack — so Dev and UAT can be stood up.

We are not claiming production evidence. Working logs, security operations, compliance proofs and a proven day-one estate are what we bring after UAT, to a later sitting. A longer copy of this deck is not that sitting.

I will take about thirty-five minutes. The rest of the hour is yours.

Five plays when you do not know

Play 1 — Cite and stop

That decision is recorded in ADR-0XX. I will not re-litigate it from memory. Happy to walk the clause after the sitting if needed.

Play 2 — Name the owner

The structure is Architecture's. The remaining acceptance sits with [Deepali / Shivanshi / bank network / Apigee team]. I will not speak for their residual.

Play 3 — Action, dated, non-blocking

Fair question. I do not have a measured answer in the room and I will not invent one. Action: we return by [date] with [owner]. That item does not change the Dev/UAT VPC shape we are asking you to review today.

Play 4 — Later sitting

That is a production, DR-readiness or VA-PT question. We will bring evidence to the second ARB. Today is the intended design, so Dev and UAT can be stood up.

Play 5 — Never guess

I will not guess an IP, a pentest result, a restore-drill time, or a CIS register class. Guessing those in this room would be the actual control failure.

Slide 1. Title (1 min · running 1)

SAY: Good morning. This is the first architecture review of the Insurance Distribution Platform.

Today we walk the intended design: the problem, one sale as it will actually run, the runtime, and the stack — so Dev and UAT can be stood up.

We are not claiming production evidence. Working logs, security operations, compliance proofs and a proven day-one estate are what we bring after UAT, to a later sitting. A longer copy of this deck is not that sitting.

I will take about thirty-five minutes. The rest of the hour is yours.

IF ASKED: If someone asks whether this is production approval — no. Say it once, park it, keep walking.

DO NOT: Do not say the architecture was designed by AI. Do not claim logs, VA/PT or DR drills as done.

Slide 2. Two sittings — design now, evidence later (2 min · running 3)

SAY: Left is today: intended design, Dev and UAT, your comments. Right is after UAT: a production sitting with evidence that logging is capturing, security ops are running, compliance is in the pack, and the day-one services actually work. We will not pretend those proofs exist this morning.

IF ASKED: If they want one ARB for everything — we still cannot evidence a pentest of an unvended estate. Staged review matches how landing zones are vended.

DO NOT: Do not promise a production date. Kalpana schedules sitting two after UAT.

Slide 3. Why this platform exists (2 min · running 5)

SAY: Four pictures, one point: a licensed corporate agent must own the evidence of a Life sale. Suitability on the RM glass, OTP and premium on the customer phone, a policy only when money and issuance agree. Redirecting the customer to an aggregator site does not produce that pack.

IF ASKED: Health, Motor and DIY are later horizons. Do not design them here.

DO NOT: Do not invent a Product signature.

Slide 4. How one sale actually runs (5 min · running 10)

SAY: Walk the ribbon left to right. The RM stands with NIP-APP. Suitability is a gate on that device — no quote without it. Consent and premium are the customer's phone, not the iPad. Quote and proposal go Hub then adapter. Policy is last, and only after reconciled. The gold line is an orchestrated saga: Journey Orchestration is the one record of where the sale is. Flutter never calls the aggregator, the database, or Apigee.

IF ASKED: Why not one InsuranceService? Health later must not rewrite Life. Quote and suitability are different systems of record.

DO NOT: Do not accept RM-pays-for-the-customer as a UAT exception. Do not call Kafka the audit log.

Slide 5. How a session reaches the application (3 min · running 13)

SAY: You cannot curl a pod from the internet. If asked why not a public ALB — it would put a public target in front of a front door we already have. ADR-018. That is a Security exposure decision, not a Dev convenience.

IF ASKED: FAQ on public ALB. Play 2 if they insist.

DO NOT: Do not agree to a public ALB just for Dev.

Slide 6. How the platform calls a partner (2 min · running 15)

SAY: The adapter base URL is the Apigee proxy, never the aggregator host. I will not read IPs. That action does not block vpc-dev.

IF ASKED: Play 3, DEP-20260914-apg. Dev uses stubs.

DO NOT: Do not invent IPs.

Slide 7. Where a request runs (2 min · running 17)

SAY: Attach as a spoke. Inbound as you saw. Outbound through Apigee. I will pause here if you want the drawing; otherwise I protect discussion time. If this picture disagrees with an ADR, the ADR wins.

IF ASKED: Previous two slides are the same facts in sequence.

DO NOT: Do not walk every box.

Slide 8. How Dev and UAT are isolated (1 min · running 18)

SAY: Five accounts. Dev is a VPC inside UAT, not a sixth account. Stubs cannot ride a production CBS route. Production is drawn so you see blast radius — we are not vending it today.

IF ASKED: Split Dev account is a Cloud exception we are not requesting.

DO NOT: Do not offer to vendor production while we are here.

Slide 9. What we run — edge, AWS, operate (3 min · running 21)

SAY: Four clusters, not a shopping list. Edge is Cloudflare, F5-XC, Apigee — they do not sit in our VPC. Compute is EKS behind API Gateway and an internal ALB. Data is Aurora PostgreSQL — one cluster, schema per context — not a public RDS. Events on MSK, fed by an outbox. Keys in KMS, secrets in Secrets Manager, telemetry in CloudWatch and CloudTrail. OpenSearch is operational search, not the audit pack.

IF ASKED: Why not RDS? Aurora PostgreSQL is the recorded pin (ADR-008). Why not self-managed Kafka on EKS? MSK is the managed backbone; the outbox remains source of truth.

DO NOT: Do not add Istio, Cognito, or a warehouse to look more complete. They are not R0.

Slide 10. How we build it (3 min · running 24)

SAY: Experience is Flutter — one project, web, APK, IPA. Services are Java 21 and Spring Boot 3.5 on EKS. Coordination is an orchestrated saga, not a choreography: Journey Orchestration is queryable when a sale stops. Outbox then MSK. 1SB JSON dies in the adapter. Tokens never reach the glass.

IF ASKED: They said Jetty — we run Java 21 LTS. Spring Boot 3.5 is the BOM in repo. Saga is recorded in the domain model \$5, not a slide invention.

DO NOT: Do not start a language war. Do not claim a saga framework product — it is the Journey service plus state, not a third-party BPM.

Slide 11. How the services sit (2 min · running 26)

SAY: Five lanes. Flutter talks only to the BFF. The sale spine owns lead, saga, suitability, consent. Product owns catalogue, quote, proposal. Fulfilment owns payment, policy, WORM audit. Integration is Hub, 1SB adapter, Apigee. That is why Health later does not rewrite Life.

IF ASKED: Not every name is a pod today. R0 is the assisted Life cut of these lanes.

DO NOT: Do not list twenty class names. Stay on the lanes.

Slide 12. How premium is collected (2 min · running 28)

SAY: Session-create through Apigee. Customer completes 3-D Secure on their phone. Callback on a separate API Gateway route. Sold waits for reconciled. Uncertain blocks a second attempt. Timeouts do not mint money.

IF ASKED: PAN never on the RM device, never in logs.

DO NOT: Do not accept RM pays on behalf for a demo.

Slide 13. Continuity — designed, not yet drilled (1 min · running 29)

SAY: Designed, not measured. That is why this is not the production ARB.

IF ASKED: Play 4. NFR-DR-04.

DO NOT: Do not claim DR is proven.

Slide 14. Decision requested (2 min · running 31)

SAY: Please record this as the intended R0 design and allow Dev and UAT on this shape. When UAT has run, we return with evidence — logging, security ops, compliance, services on the path — not with a thicker version of these pictures. I will stop here so we can discuss.

IF ASKED: If they write only 'approved', qualify: first review, Dev/UAT vending, production ARB still required.

DO NOT: Do not leave without a written observation.

Slide 15. Appendix — network terms (appendix)

SAY: Open only if a network SME quizzes terms. You do not need BGP in this sitting.

IF ASKED: Below this table — Play 3, with SRE and bank network.

DO NOT: Do not draw BGP on a whiteboard unless SRE is speaking.

Slide 16. Appendix — if you do not have the number (appendix)

SAY: Memorise Play 3 and Play 5. Put them on a card in your pocket.

DO NOT: Do not present this slide in the main walk.

Close (30 seconds)

Please record this as the intended R0 design and allow Dev and UAT on this shape. When UAT has run, we return with evidence — logging, security ops, compliance, services on the path — not with a thicker version of these pictures. I will stop here so we can discuss.

FAQ — for the discussion window

Q1. Why not a public / external ALB like other bank apps?

NIP's AWS entry is API Gateway, then an Internal ALB only (ADR-018). A public ALB in front of that front door adds a public target we do not need. Changing it is a Security exposure decision — not a Dev convenience.

Cite: ADR-018. Do not defer — answer from the ADR.

Q2. Why not put a public ALB in Dev only?

A public Dev is a production-shaped hole. The workload has no internet gateway in every environment. We will not invent a second ingress to go faster.

Cite: ADR-018 / LLD §2. Do not defer — answer from the ADR.

Q3. Why API Gateway and Apigee — two API products?

They do different jobs. API Gateway is inbound for RM/mobile and payment callbacks. Apigee is outbound for 1SB and internal bank APIs (ADR-020). One product doing both hairpins internal APIs through the public edge or allowlists the wrong IPs at 1SB.

Cite: ADR-020. Do not defer — answer from the ADR.

Q4. Why not Apigee on the front door instead of API Gateway?

Inbound stays API Gateway. Drawing Apigee on ingress puts RM traffic on the outbound plane. We will not redesign that in this sitting.

Cite: ADR-020. Do not defer — answer from the ADR.

Q5. Why no Internet Gateway on the workload VPC?

If a workload VPC has an IGW, someone will eventually attach a public IP. The only IGW is on the inspection path. You cannot curl a pod from the internet.

Cite: LLD §2 / ADR-010. Do not defer — answer from the ADR.

Q6. What is a Transit Gateway and why do we need it?

The estate roundabout that already connects applications, edge firewalls and Direct Connect. We attach one spoke. We do not build an insurance-only hub.

Cite: Estate 18 / BE-01 / ADR-009. Do not defer — answer from the ADR.

Q7. Why not a second TGW / second Direct Connect for insurance?

The estate already has them. Cloning them is an architecture defect. Attach, do not clone (BE-01).

Cite: BE-01. Do not defer — answer from the ADR.

Q8. What is NAT? Why do we still have NAT if we use Apigee?

NAT lets private pods start outbound. It still sits on the inspection path toward Apigee. It is not what 1SB allowlists. 1SB allowlists Apigee's egress IPs (ADR-020).

Cite: ADR-010 remainder / ADR-020. Do not defer — answer from the ADR.

Q9. Please give us the IP list for 1SB now.

I will not invent IPs in this room. Action: Apigee team writes product + per-env IPs (DEP-20260914-apg). Dev uses stubs. That does not block vpc-dev.

Cite: DEP-20260914-apg. Defer OK. Shivanshi / API platform

Q10. Why Network Firewall instead of a FortiGate pair in our VPC?

FortiGate already exists in the hub edge VPC. Dropping another pair in the spoke clones firewall operations. Spoke NFW may inspect pod→Apigee; Security accepts that remainder.

Cite: ADR-010 / ASM-012. Defer OK. Deepali

Q11. Why F5 Distributed Cloud, not BIG-IP in AWS?

On this estate F5 is F5-XC SaaS, outside AWS. An in-VPC BIG-IP icon was a diagram mistake and was retracted in ADR-018.

Cite: ADR-018. Do not defer — answer from the ADR.

Q12. Why Cloudflare, not CloudFront?

Cloudflare Enterprise is the north-south CDN/DDoS standard for this perimeter. CloudFront would be a second CDN for the same job.

Cite: ADR-018. Do not defer — answer from the ADR.

Q13. Why Internal ALB, not NLB or a public Kubernetes LoadBalancer?

We need HTTP path routing: / to nip-web, /api to BFF. That is ALB. A Service type LoadBalancer with a public IP is the exposure we refused.

Cite: LLD §3. Do not defer — answer from the ADR.

Q14. Why EKS, not ECS or Lambda everywhere?

EKS is listed IaaS on this estate. Lambda-for-everything does not match long-running insurance journeys or private VPC-only data stores. We are not anti-Lambda; we are anti-rewriting the platform as functions.

Cite: LLD BOM / AP-09. Do not defer — answer from the ADR.

Q15. Why Java 21 / Spring Boot, not Node or .NET?

LTS, already in the programme, Spring Boot 3.5 in support. A language war does not change a trust boundary. We will not restart R0 on a new runtime.

Cite: Lifecycle paper. Do not defer — answer from the ADR.

Q16. Is that Jetty 21?

No. The runtime pin is Java 21 LTS with Spring Boot 3.5. Jetty is not the recorded server pin.

Cite: Lifecycle paper / Gradle BOM. Do not defer — answer from the ADR.

Q17. Are you using Postgres RDS?

Aurora PostgreSQL — one cluster, schema per bounded context (ADR-008). Not a public RDS instance, not one database per microservice at R0.

Cite: ADR-008 / LLD BOM. Do not defer — answer from the ADR.

Q18. Why Saga? Is this a BPM product?

Orchestrated saga owned by Journey Orchestration (#9). Not choreography, not a third-party BPM. One queryable record of where the sale is and why it stopped. Domain model §5.

Cite: 01-domain-model §5 / HLD 2.6. Do not defer — answer from the ADR.

Q19. When do we see production logging and security evidence?

After UAT. This sitting is intended design for Dev/UAT. Sitting two brings working logs, security ops, compliance pack, VA/PT and a timed restore. We will not invent those proofs today.

Cite: This sitting's ask. Do not defer — answer from the ADR.

Q20. Why not one InsuranceService monolith?

Every rule change would be a release, and Health later becomes a rewrite. Suitability and quote are different systems of record.

Cite: 03 SAD / R0-E2E §5. Do not defer — answer from the ADR.

Q21. Why Flutter?

One project, three artefacts: web, APK, IPA. Tokens never on the device. Three native apps would triple the control surface.

Cite: R0-E2E §2. Do not defer — answer from the ADR.

Q22. Why Keycloak if we have Active Directory?

AD is workforce only (TI-01). Partners must not enter AD. Workforce verification is the AD-verify API, never LDAP from EKS.

Cite: ADR-020 / TI-01. Do not defer — answer from the ADR.

Q23. Why not LDAP from EKS to AD? It is simpler.

LDAP from a workload cluster to AD is a new credential path and a new blast radius. The AD-verify API already exists. We call it privately through Apigee.

Cite: ADR-020. Do not defer — answer from the ADR.

Q24. Why is Dev inside UAT? That is not isolation.

Isolation is two VPCs, two route tables, namespaces, schemas and prefixes. Stubs cannot use the production CBS route. A second AWS account is a Cloud exception we are not requesting.

Cite: SUG-20260914-uat / ASM-017. Do not defer — answer from the ADR.

Q25. Why no CUG?

No R0 consumer for CUG. Waiver, do not provision (ASM-018).

Cite: ASM-018. Do not defer — answer from the ADR.

Q26. Why warm standby, not active-active?

NFR RTO is 1 hour. Warm standby in ap-south-2 matches that. Active-active is a different money and data problem. DR proof is sitting 2.

Cite: NFR-DR / LLD §11. Defer OK. Aarti + Shivanshi

Q27. Is DR proven?

No. Designed, not drilled (NFR-DR-04). I will not claim a restore time we have not measured.

Cite: NFR-DR-04. Do not defer — answer from the ADR.

Q28. Is this a Critical Information System?

Architecture proposes CIS because of CIF, KYC, suitability, payment orchestration and 7-year WORM. The register is Compliance + CISO. We do not self-classify.

Cite: CIS proposal. Defer OK. Shailja + CISO

Q29. Where is the VA/PT report?

It does not exist. CI has Checkstyle, Spotless, ArchUnit, JaCoCo, lockfile SCA. DAST/VA/PT is before UAT exit / production ARB. We will not pentest an environment we have not been allowed to vendor.

Cite: Pack row 11. Do not defer — answer from the ADR.

Q30. Why isn't OpenSearch / Kafka the audit store?

Search retention is not a 7-year licence evidence. Kafka topic retention is not WORM. Audit is INSERT-only + S3 Object Lock (TI-07, ADR-013).

Cite: ADR-013 / TI-07. Do not defer — answer from the ADR.

Q31. Why can't the RM pay on the iPad for the customer?

Customer-device payment is a control, not a UX preference. UAT demos use a customer-device step.

Cite: FF-14 / TB-6. Do not defer — answer from the ADR.

Q32. Why 1SB at all? Why not call insurers directly?

R0 uses 1SB as a provider route behind an adapter (TI-04). Direct insurer APIs are a later sibling adapter. The Hub contract does not change.

Cite: TI-04 / ADR-020. Do not defer — answer from the ADR.

Q33. Are we compliant with the landing-zone / SOP?

We attach to Control Tower, TGW, DX, EDGE, GitLab, Terraform, IAM IC, India SCPs. Differences are recorded ADRs: API Gateway inbound; no CUG; Dev-inside-UAT; no workload IGW. Human T4 still outstanding.

Cite: Estate 18 / ADR-018/020. Defer OK. Mahesh T4 + Shivanshi

Q34. Can we put Flutter on public S3?

No. No public buckets. Authenticated app is not a brochure site. Static assets come through nip-web on the same ingress chain.

Cite: LLD BOM / SOP. Do not defer — answer from the ADR.

Q35. Why not Istio / service mesh in R0?

Not in R0. We already have NetworkPolicy, PDP, and two reverse proxies. A mesh is a new control plane with no named R0 problem.

Cite: Lifecycle 'not in R0'. Do not defer — answer from the ADR.

Q36. Can we start Dev without Direct Connect?

Yes. Dev uses stubs. UAT needs VPN first, then existing DX as primary (ADR-009). Do not block vpc-dev on a carrier order.

Cite: ADR-009 / DEP-20260824-dx1. Do not defer — answer from the ADR.

Q37. Who signs T4 Architecture?

A human Mahesh, not this deck. We draft; we do not sign. Same for Security Board 4 and Compliance CIS.

Cite: Authority card. Do not defer — answer from the ADR.

Q38. Why Hyderabad, not another region?

India residency (TI-08) plus the DR region already in use (ap-south-2). Data does not leave India.

Cite: TI-08 / FF-08. Do not defer — answer from the ADR.

Q39. What if ARB wants a full production pack today?

We cannot evidence timed DR, VA/PT, or CIS registration today. Forcing those now either invents evidence or delays Dev/UAT indefinitely. We ask for a staged review.

Cite: This sitting's ask. Do not defer — answer from the ADR.